MODULE 4 | SESSION 14

Secure MCP Governance

Secure the server boundary before you let the model reach enterprise data.

AI-Accelerated Software Development | Foundations Program

Confidential. Prepared exclusively for Ensemble Health Partners.

MCP changes the threat model because the model is no longer only generating text.

- It is connected to tools, data, and potentially write-capable systems.
- The risk is no longer just bad output.
- The risk is bad action through a weak connector boundary.

Prompt-level filtering is not enough

Malicious tool output, poisoned upstream content, or a permissive server can bypass “be careful” style prompt controls.

Governance has to exist below the prompt

The server, transport, authorization, and logging layers are where durable control has to live.

The MCP server is not a convenience layer. It is security infrastructure.

Tools

Which capabilities exist at all, and which of them are read-only versus write-capable?

Credentials and scopes

Who can connect, what scopes are granted, and how narrowly those scopes are constrained.

Transport and authorization

How the connection authenticates, what the server enforces, and what trust assumptions are intentionally denied.

Logging and auditability

If you cannot answer who called what and what happened, the integration is not governance-ready.

Read-only first is the safest rollout default.

- Prove value before enabling writes.
- Observe actual call patterns.
- Validate logs and audit trails.
- Minimize blast radius during early adoption.

```
Server-level control questions

- Who can connect?
- Which tools exist?
- Which tools are read-only?
- Which tools are write-capable?
- What gets logged?
- What is denied by default?
```

Data poisoning and exfiltration are real MCP threats, not edge cases.

- A poisoned upstream record can change downstream behavior.
- A compromised server can return hostile context.
- A write-capable tool can move data outside the intended boundary.

Core lesson

Trust must be earned at the server, not assumed in the prompt.

Common misconception

“Internal” hosting does not make a data connection inherently safe. Weak scoping inside the boundary is still weak scoping.

The read-only HR database demo should teach governance, not database performance.

Step 1

Connect a simulated read-only HR database MCP server.

Step 2

Query safe example data and show the allowed tool surface.

Step 3

Explain why write access stays off and why that is a deliberate governance choice.

> The strongest controls are enforced where the action occurs.

```
Teaching message

- prove value read-only first
- scope credentials tightly
- log calls and ownership
- separate demonstration from permission expansion
```

Before broader rollout, the team should be able to answer these governance questions.

Authentication

Is the server authenticated and scoped, or are we relying on a soft trust assumption?

Ownership

Are credentials rotated, owned, and attributable to a responsible team?

Read-only first

Can the integration stay read-only until logging, value, and behavior are proven?

Output risk

Would a poisoned result or hidden instruction change downstream decisions in a way we cannot audit?

If MCP is the bridge to real systems, then MCP governance is the guardrail on that bridge.

- The server, not the prompt, is where the enterprise should enforce trust.
- Read-only first, scoped auth, and auditability are the sane default rollout path.
- A weak MCP server can turn a careful model into an unsafe system.

Bridge to Session 15

Session 14 hardens tool access. Session 15 shifts to the human review layer and the cognitive debt that AI-generated code can leave behind.